ARCHITECT PERSPECTIVE

Defend the Tenant, Step by Step

Risk-Based M365 E7 Hardening Roadmap for a 100-User, Two-Admin Team

Rafał Fitt — Cybersecurity Architect

Awarded Microsoft Bug Bounties for discovering 3 vulnerabilities in MS Entra

Strategic Tagline

"Fix the gaps, reduce privilege, enforce safely, then keep watching, with an impact check before each change."



CORE TAKEAWAY A pragmatic, risk-driven security strategy tailored for lean IT operations leveraging full M365 E7 capabilities.

SCENARIO ANALYSIS

The Customer Profile & Phase 1 Baseline

Firm Profile & Constraints

SCALE & WORKSTYLE

Professional services firm with 100 users working fully remotely.

LEAN OPERATIONS

2 IT admins managing operations & security with no dedicated SOC.

LICENSING STACK

Microsoft 365 E7 (E5 + Copilot + Agent 365 + Entra Suite).

BUDGET & GAP

Budget unlocked; core deficit is in configuration & process.

⚠ **Operational Mandate:** Zero user disruption; controls must be self-enforcing.

Phase 1 Completed Checklist (10 Baseline Controls)

- ✓ MFA for Admins
- ✓ MFA for All Users
- ✓ Legacy Auth Blocked
- ✓ Sign-In Risk Policies
- ✓ User Risk Policies
- ✓ User Consent Blocked
- ✓ Teams Auto-Admit Rules
- ✓ Teams Presenters Restricted
- ✓ No Anonymous Teams Join
- ✓ SSPR Enabled for All

Note: Phase 1 controls are fully operational and will not be re-recommended. Phase 2 addresses remaining advanced gaps.

TAKEAWAY **The gap is configuration and operations, not budget.** →

Why These Controls: Threat Realities & Lessons Learned

Midnight Blizzard (2024)

- **Vector:** Password spray on legacy test account missing MFA.
- **Exploit:** OAuth app privilege abuse for persistent cloud access.
- **Lesson:** Non-production accounts & OAuth consent require strict PIM & review.

Storm-2372 Phishing

- **Vector:** Device-code authorization flow phishing attacks.
- **Exploit:** Tricks remote users into granting tokens on attacker devices.
- **Lesson:** Device-code flows must be explicitly blocked for standard remote workers.

Salesloft Drift (2025)

- **Vector:** OAuth token theft & AiTM session hijacking.
- **Exploit:** Bypassed standard OTP MFA to compromise integrated apps & AI bots.
- **Lesson:** Requires Passkeys (FIDO2) + strict compliant device CA policies.

Microsoft Digital Defense Report 2026: Identity is the primary control plane. Over 99% of identity attacks bypass basic OTP using session hijacking or illicit app consent. Phishing-resistant MFA, PIM, and governed consent are mandatory.

TAKEAWAY **Baseline MFA is not enough when sessions, apps and forgotten identities stay ungoverned.**

Sources: Microsoft Digital Defense Report 2026; Microsoft Learn Entra security guidance; Baseline Security Mode settings.

PRIORITIZED ROADMAP

Top 5 Controls Ranked by Risk & E7 Capability

Ranking Methodology: Risk Reduction (High impact on AiTM/OAuth) | **Customer Fit:** 100 Remote Users | **Operational Effort:** Sustainable for 2 Admins

RANK 1	**Phishing-Resistant MFA & Passkeys** Enforce FIDO2 / Windows Hello for Business + TAP for onboarding. Bypasses AiTM proxies.	E7 CAPABILITY Entra ID P2 + Auth Strengths
RANK 2	**PIM & Break-Glass Emergency Accounts** Zero standing admin privilege; time-bound role activation + 2 FIDO2 break-glass accounts.	E7 CAPABILITY Entra Privileged Identity Mgmt
RANK 3	**Session & Token Protection (Block Device-Code Flow)** Compliant-device CA policy + block device-code flow to prevent token theft & phishing.	E7 CAPABILITY Conditional Access & Intune
RANK 4	**Governed Apps & Agent 365 AI Governance** Admin consent workflow, review existing grants, quarterly access reviews for AI agents.	E7 CAPABILITY Agent 365 + Defender Cloud Apps
RANK 5	**Automated XDR SecOps & Operating Rhythm** Safe Links, Safe Attachments, Automatic Attack Disruption, and fixed 15-min daily/weekly rhythm.	E7 CAPABILITY Microsoft Defender XDR (MDO/MDE)

TAKEAWAY **Every control uses an E7 capability the customer already owns.**

Controls 1 & 2: Phishing-Resistant Auth & Zero Standing Admin

CONTROL 1 Phishing-Resistant MFA

Risk	Adversary-in-the-Middle (AiTM) credential proxying & SMS/OTP relay attacks.
Tech Rollout	Deploy FIDO2 security keys & WHfB. Mandatory Authentication Strengths policy in CA.
Onboarding	Use Temporary Access Pass (TAP) for zero-friction user registration.
Tradeoff	Key distribution logistics vs. 100% resistance to web-phishing attacks.

Enforcement Gate: 100% of remote workers onboarded with FIDO2 / WHfB.

CONTROL 2 PIM & Emergency Accounts

Risk	Permanent admin privileges exposed 24/7 to lateral movement & credential theft.
Tech Rollout	Convert all 2 admins to *Eligible-Only* roles with MFA + justification + max 4h duration.
Break-Glass	2 dedicated emergency accounts (FIDO2, 16+ char, excluded from CA/PIM, continuously monitored).
Tradeoff	30-second delay for elevation vs. elimination of standing tenant privilege.

Enforcement Gate: Zero permanent admin roles active in tenant.

TAKEAWAY **Passkeys cannot be replayed by a fake sign-in page, and admin power exists only while used.**

Controls 3 & 4: Session Security & Governed AI/Apps

CONTROL 3 Session & Token Protection

Risk	Primary Refresh Token (PRT) theft & device-code phishing exploiting remote devices.
Tech Rollout	Block device-code flow via CA (run Report-Only for 14 days first to verify no legacy tools break).
Compliance Gate	Require Intune compliant device or MFA session control for all M365 apps.
Tradeoff	Restricts unmanaged personal PC access; managed BYOD/MAM policy required.

Enforcement Gate: Device-code block enforced with zero audit log hits.

CONTROL 4 Governed Apps & Agent 365

Risk	Over-privileged OAuth apps & unmonitored Copilot AI agents exfiltrating data.
Tech Rollout	Enable Admin Consent Workflow with designated business reviewers.
Historic Audit	Review & revoke existing high-risk OAuth grants baseline settings missed.
Tradeoff	24h SLA for new app integrations vs. zero unauthorized tenant access.

Enforcement Gate: 100% of AI agents & OAuth apps audited quarterly.

TAKEAWAY Existing consent grants are not revoked by the baseline setting, so an explicit review is needed.

Control 5: Automated XDR & Operating Rhythm for Two Admins

AUTOMATION Defender XDR Protections

Safe Links & Attach.	Time-of-click URL re-inspection & dynamic attachment detonation.
QR-Phish Defense	OCR image analysis scanning embedded email QR codes (Quishing).
Attack Disruption	Instantly isolates infected endpoints & disables compromised user tokens automatically.
Dual-Admin Alerting	Simultaneous high-severity alerts to both admins via email + Teams webhook.

Operating Rhythm (2-Admin Model)

WEEKLY 15 MINS	Triage remaining XDR alerts, inspect PIM elevation logs, review TAP issuance history.
MONTHLY 2 HOURS	Execute Entra Access Reviews, audit pending OAuth app requests, check CA report logs.
QUARTERLY HALF DAY	Test break-glass login, review AI-agent permissions, update incident response runbooks.

Tradeoff: *Initial alert noise requires policy tuning during stage 1 to prevent fatigue.*

TAKEAWAY **With no SOC, automation and a fixed rhythm replace staffing.**

Risk-to-Impact Mapping Matrix

SECURITY RISK	RECOMMENDED CONTROL	WHY IT MATTERS	CUSTOMER IMPACT
1 **AiTM & MFA Bypass**	Passkeys (FIDO2 / WHfB) + TAP	Cryptographically binds domain to auth token; immune to reverse proxies.	Eliminates phishing credential theft for all 100 users.
2 **Standing Privilege Compromise**	Entra PIM + 2 Break-Glass Accounts	Admins operate as standard users; roles elevated on-demand for max 4h.	Zero standing admin exposure if an admin token is stolen.
3 **Token Theft & Phishing**	Compliant CA + Block Device-Code	Stops device-code exploits & restricts cloud access to healthy managed PCs.	Prevents rogue external device authorization.
4 **Illicit OAuth & Rogue AI**	Admin Consent Workflow + Audit	Prevents silent data exfiltration via third-party apps & Copilot agents.	Full visibility & control over tenant integrations.
5 **Unmonitored Incidents**	Defender XDR Disruption & Rhythm	Automated response stops ransomware propagation in seconds without a SOC.	2-admin team maintains 24/7 security posture effortlessly.

TAKEAWAY **Each risk maps to one control and one measurable outcome.**

IMPLEMENTATION ROADMAP

Step-by-Step Gated Rollout (4 Stages)

1. Check Impact > 2. Pilot Group > 3. Enforce Policy > 4. Monitor & Refine

STAGE 1

Fix the Gaps

Issue TAP to pilot users; onboard Passkeys/FIDO2 & WHfB. Verify zero sign-in blocks.

Gate Criteria: 100% accounts MFA-capable.

STAGE 2

Reduce Privilege

Configure PIM for both admins; provision & test 2 break-glass emergency accounts.

Gate Criteria: Zero standing admin access.

STAGE 3

Enforce Safely

Block device-code flow (report-only first); enforce CA compliant-device & Admin Consent.

Gate Criteria: Clean report-only audit logs.

STAGE 4

Keep Watching

Enable Defender Attack Disruption; activate weekly/monthly operating rhythm for 2 admins.

Gate Criteria: Review log active & maintained.

TAKEAWAY Security is a journey, not a switch; each step is small, tested and reversible.

OUTCOMES & TARGET METRICS

Posture Improvement, KPI Targets & Next Steps

⚠ BEFORE: Initial State

Basic OTP MFA enabled, standing admin privileges, unmonitored OAuth apps, manual incident response.

AFTER: Hardened E7 Posture

Phishing-resistant passkeys, Zero Standing Access via PIM, governed AI agents, automated XDR disruption.

TARGET KPI 1

100%

Accounts MFA-Capable (FIDO2 / WHfB)

TARGET KPI 2

0

Standing Admins (Eligible-Only via PIM)

TARGET KPI 3

0

Unreviewed App & AI Agent Grants

TARGET KPI 4

Same Day

Triage for High-Severity Alerts

Looking Ahead: Transition to **Passwordless by default** across all endpoints & expand **Agent 365 AI-agent automated governance**.

TAKEAWAY **Fix the gaps, reduce privilege, enforce safely, then keep watching.** →

Sources: Microsoft Digital Defense Report 2026; Microsoft Learn Entra security guidance; Baseline Security Mode settings.